

Chapter 06 인증

목차

6.1 개요

6.2 인증 방법

6.3 패스워드

6.4 생체인증

6.5 당신이 가지고 있는 어떤 것

6.6 이중 인증

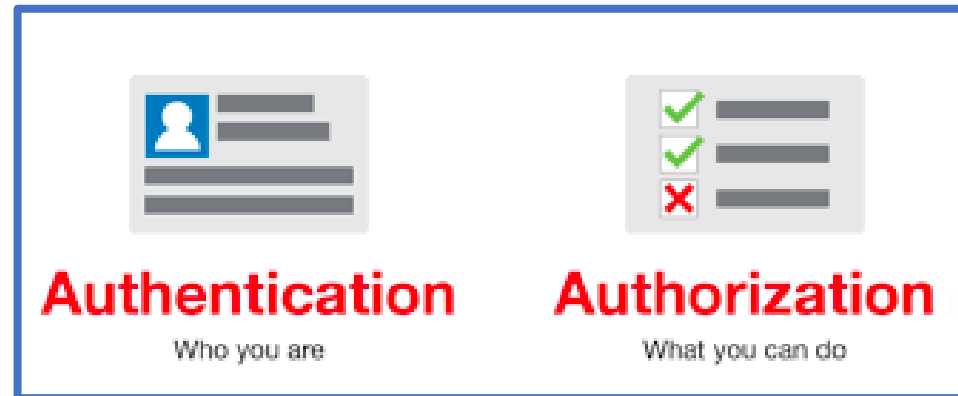
6.7 통합인증과 웹 쿠키

6.8 요약

6.1 개요

➤ 접근제어(access control)

- 시스템 자원의 접근과 관련된 모든 보안 주제를 통칭하는 용어
- 인증과 인가
 - 인증(authentication) : 당신은 당신이라고 주장하는 사람이 맞는가?(신원 확인)
 - 인가(authorization) : 당신은 그렇게 하도록 허락을 받았는가?(권한 부여)



사용자 인증 방식

➤ 알고 있는 것을(지식) 확인

- Password, Pass Phrase, PIN(Personal Id. Number)
- 단점: 망각, 남이 추측 가능, 남에게 알려줌
- 장점: 원거리 신원확인 가능



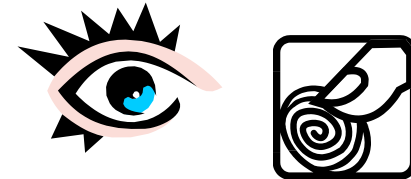
➤ 가지고 있는 것을(소유물) 확인

- 열쇠, 신분증, 도장, Token, Smartcard, ...
- 단점: 분실, 도난, 복제, 남에게 빌려줌
- 장점: 기억할 수 없이 긴 암호키 저장 가능

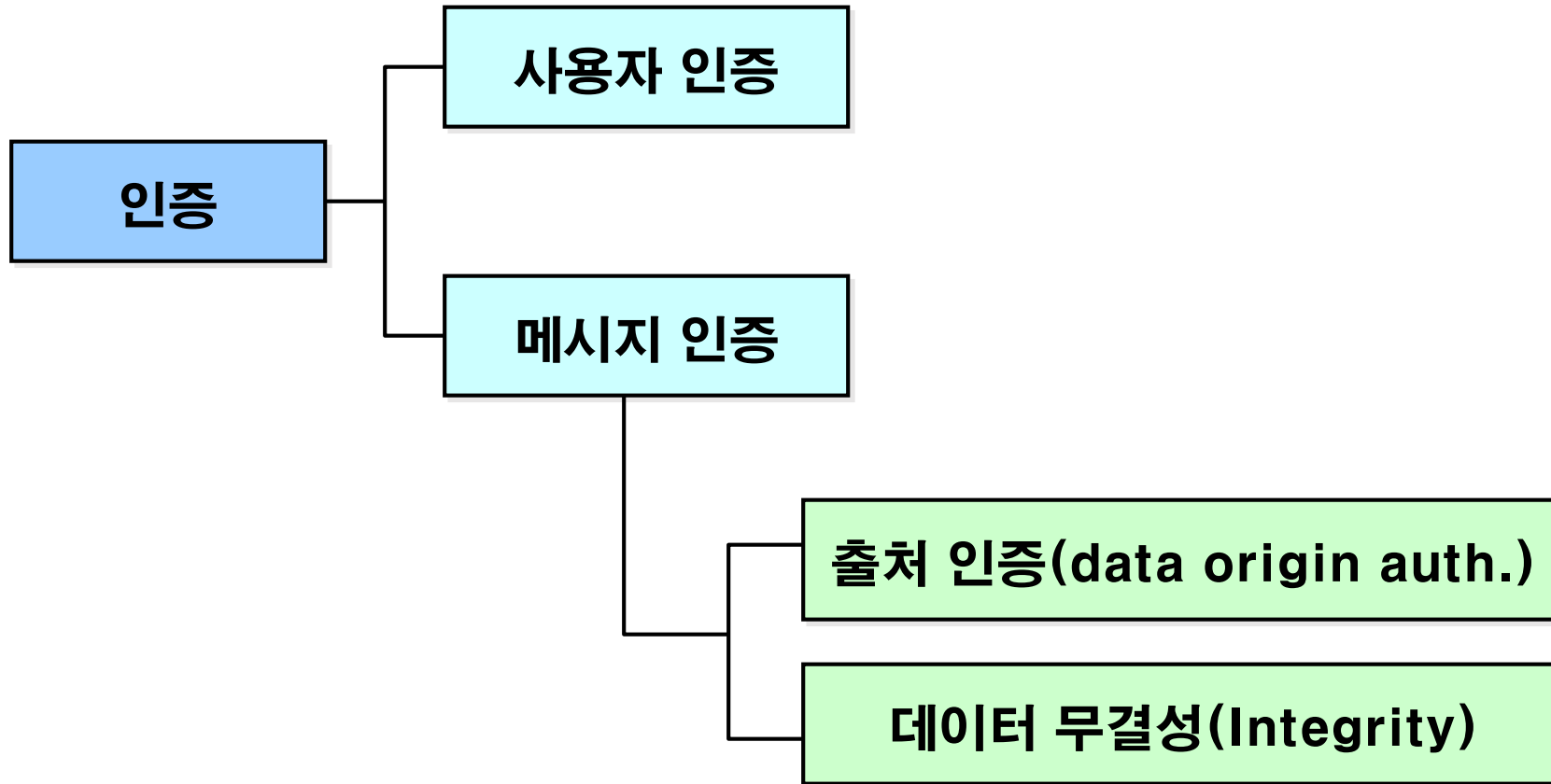


➤ 그 사람 자체의 어떤 것(신체적/행위적 특징) 확인

- 신체적 - 지문, 얼굴모양, 손모양, 망막, DNA, ...
- 행위적 - 목소리, 수 서명, Typing Dynamics, ...
- 장점: 복제 불가능. 비밀번호 유지에 필요한 비용 절감
- 단점 : 유출 시 사생활 침해 및 도용 피해



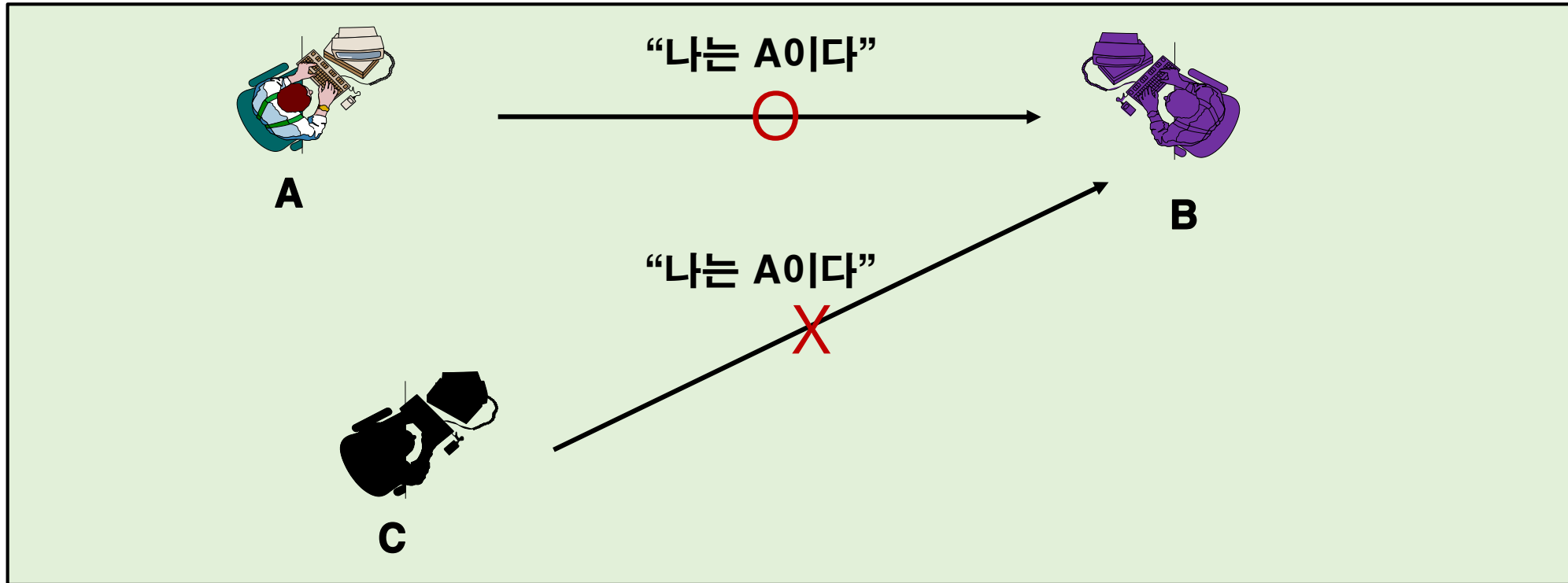
[참고] 인증(Authentication)



사용자 인증

➤ 정당한 사용자를 확인하는 과정

- 사용자 A가 사용자 B에게 자신이 사용자 A임을 증명
- A를 제외한 다른 사람은 자신이 A인척 할 수 없어야 함



6.3 패스워드

➤ 이상적인 패스워드

- 사용자가 알고 있고 **사용자가 알고 있는 것을 컴퓨터가 검증할 수 있어야 함**
- 무제한으로 컴퓨팅 자원에 접근할 수 있는 다른 누구라도 **추측할 수 없는 것**이어야 함

➤ 패스워드 방식의 특징

- 패스워드를 이용한 인증은 구축 비용이 저렴하고 사용자 편의성이 높아 널리 사용됨
- ATM 카드나 스마트 폰에서 사용하는 PIN 번호는 패스워드와 동일하게 동작
- 패스워드는 사전공격(dictionary attack)에 근본적으로 취약하므로, 충분한 보안성을 확보하기 어려움
 - 사전 공격 : 사전에 있는 단어를 순차적으로 입력하여 패스워드를 찾는 공격

6.3 패스워드

➤ 키 vs. 패스워드

- 트루디가 64비트 키를 사용하는 대칭 암호로 암호문 메시지를 해독한다고 가정
- 키는 무작위로 선택되었으며 다른 공격 방법이 없음
- 트루디는 정확한 키를 찾아내기 전에 평균적으로 2^{63} 개의 키를 시도해 봐야만 함
- 트루디가 앨리스의 패스워드를 추측하고자 하는데 앨리스의 패스워드는 8자 길이이며 각 글자는 256개 중 선택 가능한 것으로 이루어져 있다고 가정

가능한 패스워드 $256^8 = 2^{64}$ 개

- 그러나 사용자는 기억하기 쉬운 패스워드를 선택할 가능성이 높으므로, 트루디는 2^{63} 개 보다 훨씬 더 적은 수를 시도하여 패스워드를 알아낼 가능성이 있음

6.3 패스워드

➤ 패스워드 선정

▪ 취약한 패스워드

- Frank, Pikachu, incorrect, 10252010, AustinStamp

▪ 보안을 고려해 사용자들은 **다른 사람이 추측하기에 어려운 패스워드를 선택**해야 함

- jflej(43j-EmmL+y : 트루디가 알아내기 어렵겠지만 엘리스가 기억하기도 어려움
- 09864376537263 : 대부분의 사용자가 기억하기 어려움
- FS&7Yago("Four score and seven years ago"라는 문구(Passphrase)에서 생성) : 엘리스가 기억하기에는 쉬우면서 트루디가 알아내기에는 다소 어려움

6.3 패스워드

➤ 패스워드 실험

- 그룹 A : 적어도 여섯 문자로 된 패스워드 선정
 - 패스워드의 약 30%가 해독하기 쉬웠음
 - 그룹 B : 패스프레이즈에 근거해서 패스워드 선정
 - 패스워드의 약 10%가 해독됨
 - 그룹 C : 8자리의 문자를 무작위로 선택해 패스워드 구성
 - 패스워드의 약 10%가 해독됨
-
- 사용자들이 패스워드를 선택할 때 해줄 수 있는 최선의 조언은 단어에 기반한 긴 패스프레이즈를 선택하라는 것

6.3 패스워드

[패스워드 크랙에 소요되는 시간]

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	3 secs	6 secs	9 secs
5	Instantly	4 secs	2 mins	6 mins	10 mins
6	Instantly	2 mins	2 hours	6 hours	12 hours
7	4 secs	50 mins	4 days	2 weeks	1 month
8	37 secs	22 hours	8 months	3 years	7 years
9	6 mins	3 weeks	33 years	161 years	479 years
10	1 hour	2 years	1k years	9k years	33k years
11	10 hours	44 years	89k years	618k years	2m years
12	4 days	1k years	4m years	38m years	164m years
13	1 month	29k years	241m years	2bn years	11bn years
14	1 year	766k years	12bn years	147bn years	805bn years
15	12 years	19m years	652bn years	9tn years	56tn years
16	119 years	517m years	33tn years	566tn years	3qd years
17	1k years	13bn years	1qd years	35qd years	276qd years
18	11k years	350bn years	91qd years	2qn years	19qn years

※ hivesystems.io(2024년)

6.3 패스워드

[세계적으로 가장 많이 이용하는 비밀번호 TOP 30]



Top 30 Most Used Passwords in the World



1	123456	11	abc123	21	princess
2	password	12	1234	22	letmein
3	123456789	13	password1	23	654321
4	12345	14	iloveyou	24	monkey
5	12345678	15	1q2w3e4r	25	27653
6	qwerty	16	000000	26	1qaz2wsx
7	1234567	17	qwerty123	27	123321
8	111111	18	zaq12wsx	28	qwertyuiop
9	1234567890	19	dragon	29	superman
10	123123	20	sunshine	30	asdfghjkl

※ 출처 : SafetyDetectives(2024)

6.3 패스워드

➤ 패스워드를 통한 시스템 공격

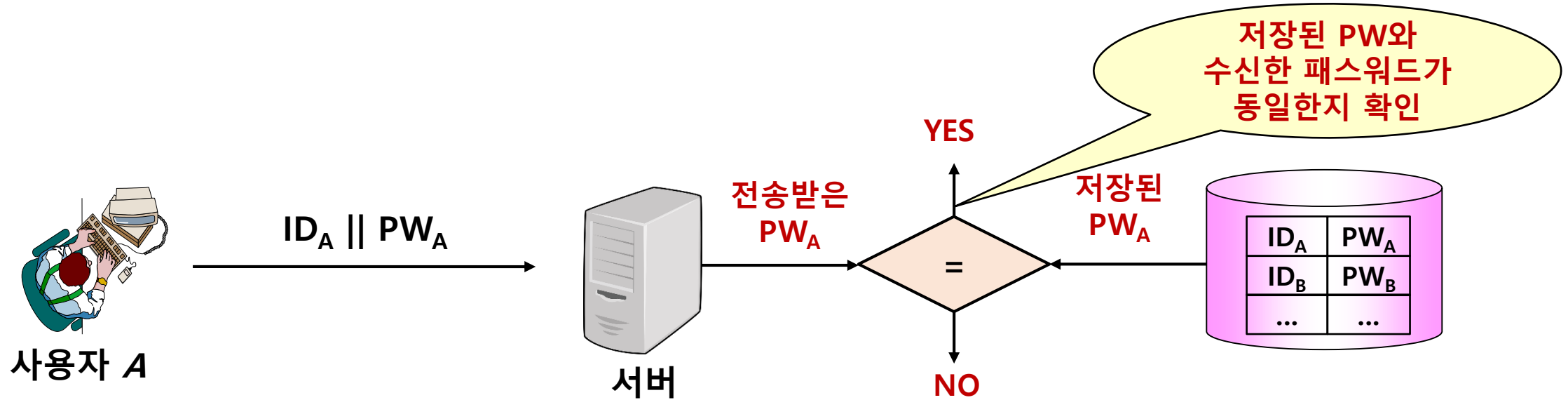
- 트루디가 외부인이며, 특정 시스템에 대한 접근 권한이 없다고 가정
- 트루디는 내부 사용자나 관리자의 패스워드를 추측하는 공격을 시도할 수 있음
- 약한 패스워드가 하나라도 있으면, 내부 시스템에 접근 권한을 획득할 수 있음
- 패스워드에 대한 공격이 감지되었을 때의 대응방안 예
 - 일반적으로 틀린 패스워드를 3회 이상 반복해서 시도하면 시스템은 잠금 상태가 됨
 - 트루디는 모든 계정을 대상으로 각 계정에 대해 3회 패스워드 추측을 반복해서 시도함으로써 모든 계정을 잠금 상태에 있도록 만들 수 있음

6.3 패스워드

➤ 패스워드 검증

- 컴퓨터(서버)는 사용자 인증을 수행하기 위해 패스워드에 접근할 수 있어야만 함
- 패스워드를 평문 형태로 저장하는 경우, 공격자의 주요 목표가 될 수 있음
- 패스워드가 저장된 파일이 노출되더라도, 패스워드의 안전성을 유지하기 위한 방법 필요
 - ① **패스워드 파일을 대칭키 암호 방식으로 암호화하는 방법**
 - 패스워드를 검증하기 위해 매번 복호화를 수행해야 함
 - ② **해시 함수의 일방향성을 이용하여 패스워드의 해시 값을 저장하는 방법**
 - 예: 앨리스의 패스워드가 servenoterampartoriginal일 때 파일에 다음과 같이 저장
$$y = h(\text{servenoterampartoriginal})$$

6.3 패스워드

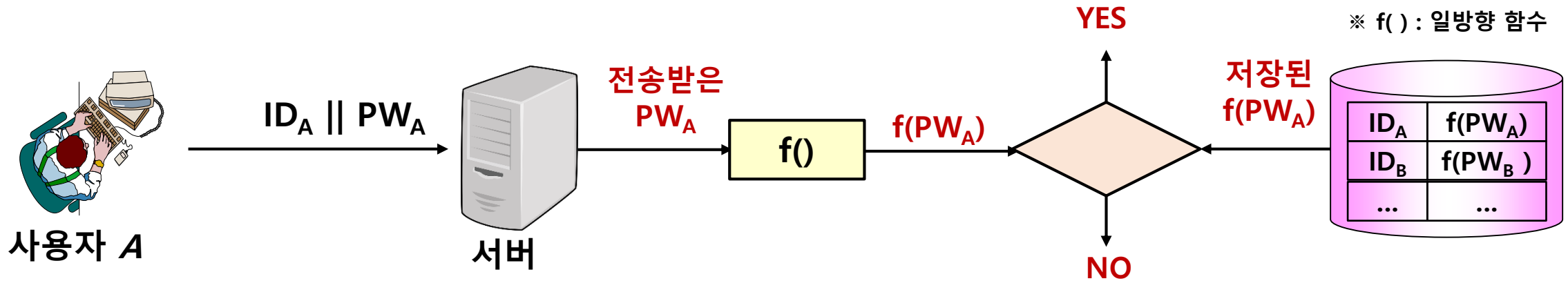


[패스워드를 평문으로 저장하는 인증 방식 예]

❖ 문제점 ?

- 패스워드 노출 ➡ 도청에 의한 재전송 공격 가능
- 서버의 패스워드 디렉토리 보안 문제
- 패스워드의 길이가 짧은 경우, 사전 공격(dictionary attack)에 취약

6.3 패스워드



[일방향 해시 함수를 이용한 패스워드 저장 예]

❖ 문제점 ?

- 패스워드 노출 ➡ 도청에 의한 재전송 공격 가능
- 패스워드의 길이가 짧은 경우, 사전 공격(dictionary attack)에 취약

6.3 패스워드

➤ 사전 공격(dictionary attack)

- 패스워드로 추정되는 값에 대한 일방향 함수 값을 계산하여 결과 값과 패스워드의 일방향 함수 값을 비교하는 공격 방법
- 해결책 : salt 추가

$$f(\text{패스워드} || \text{salt}) = R$$

- Salt : 패스워드를 추측하는 사전공격이나 무차별 대입 공격의 어려움을 증가시키지 위해 시스템에 추가하는 정보

안전한 패스워드

패스워드란?

이용자가 인터넷 사이트에 로그인 할 때, 허가된 이용자임을 확인하는데 이용되는 문자열입니다. 이용자의 패스워드가 노출되면, 이용자의 개인 메일 정보, 금융정보 등이 타인에게 유출될 수 있습니다. 따라서 이용자는 안전한 패스워드를 설정하고 이용하여야 하며, 또한 안전하게 관리해야 합니다.

안전한 패스워드란?

제3자가 쉽게 추측할 수 없으며, 시스템에 저장되어 있는 이용자 정보 또는 인터넷을 통해 전송되는 정보를 해킹하여 이용자의 패스워드를 알아낼 수 없거나 알아낸다 하더라도 많은 시간이 요구되는 패스워드를 말합니다.

두 종류 이상의 문자구성과 8자리 이상의 길이로 구성된 문자열

※ 문자종류는 알파벳 대문자와 소문자, 특수문자, 숫자의 4가지임

또는

10자리 이상의 길이로 구성된 문자열

※ 숫자로만 구성할 경우 취약할 수 있음

※ 한국인터넷 진흥원, "패스워드 선택 및 이용 안내서" (2019년)

패스워드 안전성 체크 리스트

✓ 특정 패턴을 갖는 패스워드

동일한 문자의 반복

예) 'aaabbb', '123123'

키보드 상에서 연속한 위치에 존재하는 문자들의 집합

예) 'qwerty', 'asdfgh'

숫자가 제일 앞이나 제일 뒤에 오는 구성의 패스워드

예) 'security1', '1security'

✓ 제3자가 쉽게 알 수 있는 개인정보를 바탕으로 구성된 패스워드

가족이름, 생일, 주소, 휴대전화번호 등을 포함하는 패스워드

✓ 이용자 ID를 이용한 패스워드

예) 이용자의 ID가 'KDHong'인 경우, 패스워드를 'KDHong12' 또는 'HongKD'로 설정

✓ 한글, 영어 등을 포함한 사전적 단어로 구성된 패스워드

예) '바다나라', '천사10', 'love12'

✓ 특정 인물의 이름이나 널리 알려진 단어를 포함하는 패스워드

컴퓨터 용어, 사이트, 기업 등의 특정 명칭을 포함하는 패스워드
유명인, 연예인 등의 이름을 포함하는 패스워드

✓ 숫자와 영문자를 비슷한 문자로 치환한 형태를 포함한 구성의 패스워드

예) 영문자 'o'를 숫자 '0'으로, 영문자 'l'을 숫자 '1'로 치환

✓ 기타

시스템에서 초기에 설정되어 있거나 예제로 제시되고 있는 패스워드 한글의 발음을 영문으로, 영문단어의 발음을 한글로 변형한 형태의 패스워드

예) 한글의 '사랑'을 영어 'SaRang'으로 표기, 영문자 'LOVE'의 발음을 한글 '러브'로 표기

안전한 패스워드

기억하기 쉬운 패스워드 설정방법

- ✓ **특정명칭을 선택하여 예측이 어렵도록 가공하여 패스워드 설정**
특정명칭의 홀·짝수 번째의 문자를 구분하는 등의 가공방법을 통해 설정
국내 이용자는 한글 자판을 기준으로 특정명칭을 선택하고 가공하여 설정
예) '한국인터넷진흥원'의 경우, 홀수 번째 '한인넷홍'이 'gksdlssptgmd'로, 짝수 번째 '국터진원'이 'rnrxjwlsdnjs'로 사용
- ✓ **노래 제목이나 명언, 속담, 가훈 등을 이용·가공하여 패스워드 설정**
 - ※ 영문사용의 경우, 'This May Be One Way To Remember'를 'TmB1w2R'이나 'Tmb1w>r~'로 활용
 - ※ 한글사용의 경우, '백설공주와 일곱 난쟁이'를 '백설+7난장'로 구성하고 'QorTjF+7SksWkd'등으로 활용

예측이 어려운 문자구성의 패스워드 설정방법

- ✓ **영문자(대·소문자), 숫자, 특수문자들을 혼합한 구성으로 패스워드 설정**
예) '10H+20Min', '!lCan&9it' 등과 같은 구성

- ✓ **패스워드의 길이를 증가시키기 위해서는 알파벳 문자 앞뒤가 아닌 위치에 특수문자 및 숫자 등을 삽입하여 설정**

예) 'Security1'이 아니라 'Securi2t&&y'와 같은 형태로 패스워드의 길이를 늘림

- ✓ **알파벳 대·소문자를 구별할 수 있을 경우, 대·소문자를 혼합하여 설정**
특정위치의 문자를 대문자로 변경하거나, 모음만을 대문자로 변경

예) 'gkswjddqhwlsdnjs' → 'gKsWjDqHwLsDnJs', 'mrqghghgmd' → 'rNrQhGhGmD'

사이트별 상이한 패스워드 설정을 위한 방법

- ✓ **자신의 기본 패스워드 문자열을 설정하고 사이트별로 특정 규칙을 적용하여 패스워드 설정**

예) 패스워드 문자열을 '486*+'로 설정하고, 사이트 이름의 짝수 번째 문자 추가를 규칙으로 yahoo.com는 '486*+ao.o', google.co.kr는 '486*+ogec.r'등으로 활용



6.4 생체인증

➤ 생체인증(biometrics)

- '본인 자체의 어떤 것' 을 이용하는 인증 방법
- 물리적/생리적 생체 인식(physical/physiological biometrics) : 얼굴, 지문, 홍채, 귀 형상, 손가락 모양, 손 모양, 손바닥, 망막, 정맥 분기 모양 등
- 행동적 생체 인식(behavioral biometrics): 키 두드리기 행동(keystroke dynamics), 서명 인증(signature verification), 발화자 인증(speaker verification)과 같은 학습된 특성

➤ 이상적인 생체인증은 다음과 같은 특징을 만족함

- 보편성 : 모든 사람에게 적용 가능
- 구별성 : 확실한 구별이 가능해야 함
- 영구성 : 측정이 대상이 되는 신체적 특징은 영구적이고 불변이어야 함
- 수집성 : 상해없이 간단하게 수집 가능
- 신뢰성 : 실세계에서도 신뢰할 수 있어야 함
- 강건성 : 구조적으로 견고하게 동작해야 함
- 사용자 친화성 : 사용자들이 친숙하게 사용할 수 있어야 함

6.4 생체인증

➤ 생체인증 시스템에는 두 단계가 존재

■ 첫 번째 : 등록 단계

- 대상자들이 그들의 생체인증 정보를 모으고 데이터베이스에 입력하는 단계

■ 두 번째 : 인증 단계

- 생체인증 시스템이 실제로 사용자를 인증할 것인가 인증하지 않을 것인가를 결정하는 단계
- 사용자가 자신이 바로 그 사용자라고 주장하는 것에 대해 옳고 그른지를 판단하기 위해서는 사용자의 특성은 데이터베이스에 저장된 내용과 일대 일 대응이 되어야 함
- 신속, 단순, 정확해야 함

6.4 생체인증

➤ 오류의 종류

- 트루디가 앨리스인 척하고 시스템이 실수로 트루디를 앨리스로 인증하는 오류
 - FAR(False Acceptance Rate) : 실제 사용자가 아님에도 다른 사람을 사용자로 착각하여 인증이 되는 오류 비율을 기만율(fraud rate)이라고 함
- 앨리스가 자신임을 인증받으려고 하지만 시스템이 인증하는 데 실패하는 오류
 - FRR(False Rejection Rate) : 실제 사용자 임에도 다른 사람으로 착각하여 인증이 거부되는 오류 비율을 모욕률(insult rate)이라고 함
- 그 어떤 생체인증에서든 기만율 혹은 모욕률을 감소시키면 반대편은 증가하게 됨
- 기만율과 모욕률이 같도록 시스템의 매개변수를 설정하면 동일한 오류율(Euqal Error Rate)이 발생

6.4 생체인증

➤ 생체인증 예시 – 지문(fingerprint)

- 서명 형식으로 고대 중국에서 사용되었으며 역사상 다른 시대에서도 비슷한 목적으로 사용되어 옴
- 1899년 미국의 헨리 경에 의해 지문 분류법이 정착한 후에 개인 확인 시스템의 성능 향상과 함께 널리 쓰이게 됨
- 특징으로는 융선의 변형 형태인 끝점과 분기점이 주로 사용되며, 지문의 분류를 위한 특이점으로는 핵과 삼각점 사용
 - 현대의 지문 생체인증은 먼저 지문의 이미지를 캡처하는 것에서 시작 → 이미지 처리 기술을 이용하여 이미지를 개선 시킴 → 해당 이미지에서 다양한 점을 식별하여 추출



(a) 원본 지문 (b) 일부 융기선

그림 6-2 추출한 융기선

- 활용 분야 : 출입통제, 근태관리 분야, 전자상거래 인증 분야, PC 및 각종 응용프로그램 보안, 은행의 현금 인출기 및 금고 등

6.4 생체인증

➤ 생체인증 예시 - 손의 기하학적 형태(palm scan)

- 손의 모양, 즉 장문을 세밀하게 측정 : 보안 시설 출입에 사용
- 손바닥 전체에 걸쳐있는 주름, 마루, 골 등으로 이루어진 손금과 같은 사람마다 고유한 정보를 인식
- 장점
 - 손의 기하학적 형태 시스템의 한 가지 장점은 빠르다는 것
 - 인간의 손은 대칭이어서 등록된 손에 봉대를 감고 있다면 다른 손의 손바닥을 위로 가게 하여 그 손을 대신 이용할 수도 있음
- 단점
 - 아주 어리거나 아주 나이가 많은 경우 사용하기 어려움(오류율이 상당히 높음)

6.4 생체인증

➤ 생체인증 예시 - 홍채 인식(iris scan)

- 이론상으로 최고의 생체인증 방법 중의 하나
- 홍채의 앞면은 불규칙한 기복면을 가지며 동공연의 가까이에 융기된 원형의 패턴(권륜축)이라 하며, 지문과 마찬가지로 출생 시에 한번 정해지면 평생 변하지 않음
- 홍채의 발달(눈의 색깔 부분)은 복잡하여 사소한 변화도 큰 차이를 만듦
- 일란성 쌍둥이라도 다르며, 한 사람의 두 눈동자도 서로 다름
 - 1936년에 프랭크 버치 Frank Burch에 의해 제안
 - 1980년대에 제임스 본드 영화에서 홍채 인식 아이디어가 다시 살아남
 - 1986년이 되어서야 특허를 내면서 사람들이 이 기술의 잠재력을 보기 시작함
 - 1994년에 캠브리지 대학의 연구자 존 더그맨(John Daugman)이 현재 사용하고 있는 최고의 홍채 인식 접근 방법에 대한 특허를 받음

6.4 생체인증

➤ 생체인증 오류율

- 동일 오류율(기만율과 모욕률이 동등한 지점)은 서로 다른 생체인증 시스템을 비교하는 데 사용할 수 있는 측정 수단

표 6-2 생체인증 동일 오류율 [121]

생체인증	동일 오류율
지문	2.0×10^{-3}
손의 기하학적 형태	2.0×10^{-3}
음성 인식	2.0×10^{-2}
홍채 스캔	7.6×10^{-6}
망막 스캔	1.0×10^{-7}
서명 인식	2.0×10^{-2}

6.4 생체인증

➤ 생체인증 특징

- 생체인증은 불가능하지는 않지만 위조하기 어려움
- 훼손된 생체 정보는 정확하게 동작하지 않을 수 있음
- 생체인증 정보를 위조하는 것은 어렵지만 그 자체로 도난당 할 수 있음
- 공격자가 생체 인증 시스템을 공격하여 생체인증 정보 샘플을 탈취하는 경우, 다른 정보로 대체하기가 어려움
 - 노출된 암호화 키나 잊어버린 패스워드는 폐지되고 대체될 수 있는 반면에 노출된 생체인증 정보를 어떻게 폐지할지에 대해서는 불분명

6.5 당신이 가지고 있는 어떤 것

➤ '가지고 있는 어떤 것'

- 스마트폰, 스마트카드, 다른 하드웨어 토큰, 노트북 컴퓨터(MAC 주소에 기반을 둔), ATM 카드 등
- 앨리스가 스마트폰을 사용해서 밥에게 자신이 앨리스라는 것을 인증하는 예
 - 스마트폰에 기반을 둔 인증은 '가지고 있는 어떤 것(스마트폰)'과 '알고 있는 어떤 것(PIN)'을 둘 다 요구

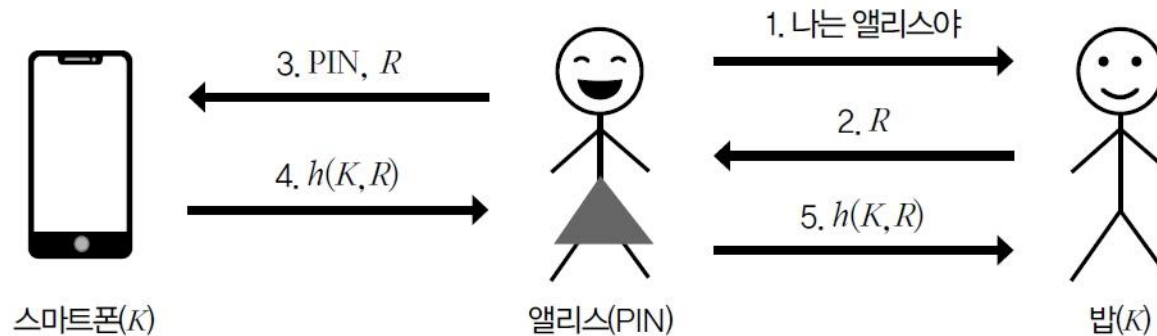


그림 6-4 인증을 위한 스마트폰

- 두 개 이상의 인증 수단을 요구하는 인증 방법을 **이중 인증 (two-factor authentication)**이라 함

6.7 통합인증과 웹 쿠키

➤ 통합인증(single sign-on)

- 사용자들은 패스워드와 같은 인증 정보를 반복해서 입력하는 것을 힘들어함
- 편리한 해결책 : 초기의 인증에는 앨리스(사용자)가 참여해야 하지만 이후에 따라 나오는 인증은 표면 뒤에서 일어나도록 하는 것 = 통합인증

➤ 웹 쿠키(web cookies)

- 앨리스가 웹 서핑을 할 때 웹 사이트는 앨리스의 브라우저에 웹 쿠키를 제공함
- 이러한 웹 쿠키는 앨리스의 브라우저에 의해 저장되고 관리되는 숫자 값임
- 웹 사이트는 앨리스가 웹 쿠키를 가지고 있는지 아닌지에 근거해서 '앨리스'를 인증할 수 있는 것임
- 더 강력한 버전에서는 처음에 앨리스를 인증하기 위해 패스워드를 사용하고 그 후에는 쿠키만으로 충분하다고 여김